

PLANTILLA DE REPORTE EJECUTIVO EN POWERPOINT

Estructura de Presentación para Junta Directiva y Stakeholders

ÍNDICE DE DIAPOSITIVAS (20 diapositivas)

1. Portada
2. Resumen ejecutivo (IGM, Clasificación, Recomendación)
3. Contexto regulatorio (NIS2, ISO 27001, NIST)
4. Metodología de evaluación
5. Resultados globales (IGM, NIST CSF, ICN)
6. Gráfico radar de dominios
7. Análisis dominio Gobernanza y Riesgos
8. Análisis dominio Vulnerabilidades
9. Análisis dominio SIEM
10. Análisis dominio Capacitación
11. Análisis dominio Cumplimiento Normativo
12. Análisis dominios restantes (resumen)
13. Matriz de brechas críticas
14. Análisis financiero (ROICS, Inversión, Beneficios)
15. Roadmap de 12 meses (Q1-Q4 2026)
16. Top 5 recomendaciones prioritarias
17. Planes de implementación detallados
18. Métricas de éxito y KPIs
19. Riesgos de implementación y mitigación
20. Conclusiones y próximos pasos

DIAPPOSITIVA 1: PORTADA

EVALUACIÓN INTEGRAL DE CIBERSEGURIDAD INFORME EJECUTIVO - REPORTE MERCURY

[Logo organización]

Organización: _____
Sector: _____
Tamaño: _____
Clasificación NIS2: _____

Período de Evaluación: _____ a _____
Fecha del Reporte: [Mes Año 2026]

Responsable: _____
Aprobado por: _____

CONFIDENCIAL - DISTRIBUCIÓN RESTRINGIDA

DIAPPOSITIVA 2: RESUMEN EJECUTIVO

HALLAZGOS CLAVE

ÍNDICE GLOBAL DE MADUREZ (IGM): 3.2 / 5.0
Clasificación: TIER 3 - ESTABLECIDO
Porcentaje: 64%



POSICIÓN: España (benchmarks 2024)
• Sector tu industria: promedio [X]
• Tu organización: [X + Y] (diferencial)



CONFORMIDAD: 68% (NIS2 + ISO 27001)
Status: PARCIALMENTE CONFORME
Acción requerida: SÍ, antes Q1 2026



ROICS: 112% en 3 años
Beneficios estimados: €4.5M
Inversión requerida: €2.1M



CRÍTICAS: 3 dominios con brecha >1.5
1. Gobernanza y Riesgos (brecha 2.0)
2. Cumplimiento Normativo (brecha 2.3)
3. SIEM (brecha 1.5)



FORTALEZAS: 2 dominios en nivel 4
• Vulnerabilidades (3.4/5)
• Controles Técnicos (3.2/5)



RECOMENDACIÓN EJECUTIVA:
"Implementación de governance mediante Mercury AVRQ
y cumplimiento de NIS2 es CRÍTICO antes de Q1 2026.
Requiere €200K en Q1 y asignación de recursos clave.
ROI justifica inversión ampliamente."

Notas del Orador (Hoja de notas):

- Enfatizar que esta evaluación es HONESTA, no optimista
- 64% no es malo, pero la tendencia debe mejorar
- NIS2 es OBLIGATORIO, no opcional
- Multas potenciales si no se cumple: €7-10M
- Beneficio: Mejor postura competitiva en licitaciones

DIAPOSITIVA 3: CONTEXTO REGULATORIO

¿POR QUÉ CIBERSEGURIDAD AHORA?

Línea de tiempo regulatoria española:

2016	→	2024	→	2026	→	2027
GDPR		GDPR Multas		NIS2 Ley		NIS2 Auditorías
Definido		Vigente		Vigente		Sancionador

REGULACIONES APLICABLES

— NIS2 (Directiva 2022/2555 UE) —
Vigencia: Ley española Q1 2026
Aplicable: Entidades Esenciales
Aplicable: Entidades Importantes
Multa Máxima: €10M o 2% facturación
Período auditoría: 12 meses post-ley

— ISO/IEC 27001:2022 —
Estándar: Certificación optativa
Beneficio: Demostración de madurez
Tiempo implementación: 12-18 meses
Costo: €30-80K (auditoría externa)

— NIST CSF v2.0 —
Framework: Orientación ejecutiva
Alineación: Universal a todos CSS
Objetivo: Nivel 3-4 (tu organización)
Horizonte: 24 meses

PREGUNTA CLAVE: ¿Tu organización está preparada?
Respuesta basada en datos: Este reporte responde.

DIAPPOSITIVA 4: METODOLOGÍA DE EVALUACIÓN

¿CÓMO SE EVALUÓ TU ORGANIZACIÓN?

1. ENCUESTA INTEGRAL (112 preguntas)
 - 12 dominios de ciberseguridad
 - Cubiertos: Gobernanza, Riesgos, Vulnerabilidades, Detección, Respuesta, Capacitación, Cumplimiento
 - Respondientes: [número] personas
 - Tasa de respuesta: [%]
2. SCORING (1-5 por pregunta)
 - 1 = Inexistente
 - 2 = Básico
 - 3 = Definido
 - 4 = Gestionado
 - 5 = Optimizado
3. ÍNDICE GLOBAL DE MADUREZ (IGM)
 - IGM = Media ponderada de dominios / 5
4. VALIDACIÓN CRUZADA
 - ✓ Revisión documental (políticas, procedimientos)
 - ✓ Entrevistas con stakeholders clave
 - ✓ Análisis técnico (SIEM, configuraciones)
5. MAPEO NORMATIVO
 - ✓ Cada pregunta vinculada a NIS2, ISO 27001, NIST
 - ✓ Conformidad calculada por requisito
 - ✓ Riesgos regulatorios identificados

CONFIABILIDAD: ± 0.3 puntos (IC 95%)

SESGO DETECTADO: +0.2 puntos (optimismo típico)

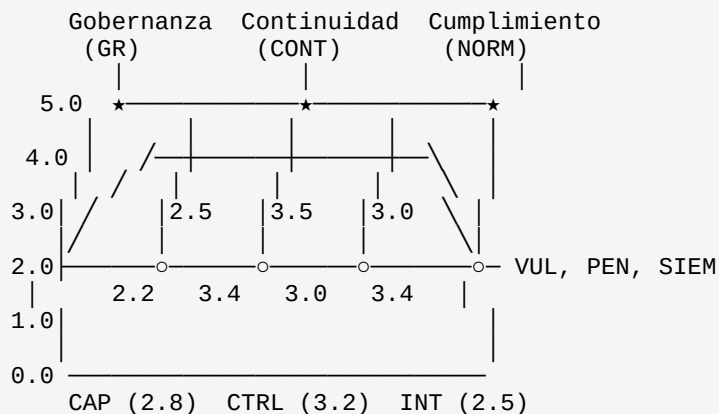
ENTIDADES SIMILARES (comparativa):

- Sector [X]: IGM promedio 3.1 → Tu 3.2 (+0.1) ✓
- Tamaño similar: IGM promedio 2.9 → Tu 3.2 (+0.3) ✓

- USA: IGM promedio 3.5 (tech-first)
- EU: IGM promedio 3.0 (regulatory-first)
- España: IGM promedio 2.8 (developing)
- Tu organización: 3.2 (ARRIBA DEL PROMEDIO ✓)

DIAPPOSITIVA 6: GRÁFICO RADAR DE DOMINIOS

DESEMPEÑO POR DOMINIO



LÍNEA INTERIOR = Puntuación Actual

LÍNEA EXTERIOR = Objetivo (4.5)

DOMINIOS CRÍTICOS (Brecha > 1.5):

- Gobernanza y Riesgos: 2.5 → 4.5 (Brecha 2.0) ●
- Cumplimiento Normativo: 2.2 → 4.5 (Brecha 2.3) ●
- SIEM e Incidentes: 3.0 → 4.5 (Brecha 1.5) ●

DOMINIOS FUERTES (≥3.3):

- Vulnerabilidades: 3.4 ✓
- Controles Técnicos: 3.2 ✓
- Continuidad: 3.5 ✓

DOMINIOS CON POTENCIAL:

- Capacitación: 2.8 (mejora rápida posible)
- Inteligencia: 2.5 (bajo presupuesto actual)

Notas técnicas PowerPoint:

- Usar gráfico radar/araña con 10 series
- Colores: Verde (>3.5), Amarillo (2.5-3.5), Rojo (<2.5)
- Incluir leyenda y valores en el gráfico

DIAPOSITIVA 7: DOMINIO - GOBERNANZA Y RIESGOS

GOBERNANZA Y RIESGOS: La Base de Todo

PUNTUACIÓN ACTUAL: 2.5 / 5.0 (CRÍTICA)

Brecha al objetivo: -2.0 puntos

Impacto: Afecta decisiones de inversión de seguridad

EVALUACIÓN DETALLADA:

x P2.1: Metodología formal de análisis de riesgos
Respuesta: "Sí, pero sin alineación a estándares"
Score: 2/5 - Parcial
Requisito: ISO 27005, NIST SP 800-30

Recomendación:

- Implementar ISO 27005 formal (3-6 meses)
- Entrenar a equipo en metodología (2 semanas)
- Documentar y comunicar framework (1 mes)

x P2.2: Cuantificación monetaria de riesgos (AVRQ/FAIR)
Respuesta: "Parcialmente; método manual"
Score: 2/5 - Manual vs automatizado
Requisito: Mercury AVRQ o FAIR Institute

Recomendación:

- Adoptar Mercury AVRQ (licencia + implementación)
- Herramienta: Automatización cuantificación
- Beneficio: Justificación financiera de inversiones
- Timeline: 2-3 meses implementación

✓ P2.3: Planes de tratamiento documentados
Respuesta: "Sí, para riesgos críticos"
Score: 3/5 - Implementado pero no exhaustivo
Requisito: Todos los riesgos con plan

IMPACTO FINANCIERO:

Inversión requerida:

- Consultoría ISO 27005: €15K
- Licencia Mercury AVRQ: €25K/año
- Tiempo interno (6 meses): €40K
- TOTAL Fase 1: €80K

Beneficio esperado:

- Decisiones ROI justificadas: €500K ahorrados/año
- Evitar inversiones ineficientes: €200K
- Cumplimiento NIS2 (evitar multas): €1M+ potencial

NET Año 1: €620K beneficio vs €80K inversión = 775% ROI

LÍNEA DE TIEMPO:

Q1 2026: Consultoría + Selección Mercury (+€80K)
Q2 2026: Implementación y capacitación
Q3 2026: Operación y refinamiento
Q4 2026: Evaluación y ajustes

DIAPPOSITIVA 8-11: DOMINIOS VULNERABILIDADES, SIEM, CAPACITACIÓN

[Estructura idéntica a Diapositiva 7, adaptada a cada dominio]

ESTRUCTURA GENERAL (Aplicar a cada dominio):

DOMINIO [X]: Puntuación [Y] / 5.0

EVALUACIÓN DETALLADA:

✓/x P[X.1]: [Pregunta] → Score [Y]/5, Brecha [Z]

✓/x P[X.2]: [Pregunta] → Score [Y]/5, Brecha [Z]

✓/x P[X.3]: [Pregunta] → Score [Y]/5, Brecha [Z]

RECOMENDACIONES TOP 3:

1. [Acción específica] (Timeline, Costo)
2. [Acción específica] (Timeline, Costo)
3. [Acción específica] (Timeline, Costo)

IMPACTO FINANCIERO:

- Inversión: €[X]
- Beneficio: €[Y]
- ROI: [%]

Nota: Mantener tono ejecutivo, números concretos,
referencias a NIS2/ISO cuando aplique.

DIAPPOSITIVA 12: RESUMEN DE DOMINIOS RESTANTES

DOMINIOS: CONTINUIDAD, CADENA SUMINISTRO, INTELIGENCIA

CONTINUIDAD DE NEGOCIO (CONT) - 3.5 / 5.0

- └ BCP documentado: ✓ (Score 4/5)
- └ DR documentado: ✓ (Score 3/5)
- └ Testing regularidad: ⚠ (Score 3/5, mejora necesaria)
- └ Brecha: 1.0 → Plan: Mejorar testing anual

CADENA DE SUMINISTRO (SUPL) - 2.9 / 5.0

- └ Evaluación proveedores: ⚠ (Score 3/5)
- └ Monitoreo incidentes terceros: x (Score 2/5)
- └ SBOM (inventario software): x (Score 2/5)
- └ Brecha: 1.1 → Plan: Implementar SBOM, monitoreo TI

INTELIGENCIA DE AMENAZAS (INT) - 2.5 / 5.0

- └ Threat intelligence feeds: ⚠ (Score 3/5)
- └ Análisis forense: x (Score 2/5)
- └ Participación ISACs: ⚠ (Score 2/5)
- └ Brecha: 1.5 → Plan: Elevar a equipo SOC experto

RESUMEN:

Estos dominios requieren mejora media pero no crítica.
Pueden abordarse después de dominios críticos (GR, NORM, SIEM).
Inversión total estimada: €400K en 24 meses.

DIAPPOSITIVA 13: MATRIZ DE BRECHAS CRÍTICAS

PRIORIZACIÓN: ¿QUÉ ARREGLAMOS PRIMERO?

DOMINIO	BRECHA	CRITICIDAD	PRIORIDAD
1. Cumplimiento Normativo	2.3	CRÍTICA (NIS2)	INMEDIATA (Q1) Acción: GNCS Costo: €150K
2. Gobernanza y Riesgos	2.0	CRÍTICA (Base)	INMEDIATA (Q1) Acción: AVRQ Costo: €80K
3. SIEM e Incidentes	1.5	CRÍTICA (EE)	CORTO (Q1-Q2) Acción: Tuning Costo: €120K
4. Vulnerab. y Parches	1.1	ALTA (raíz)	CORTO (Q2) Acción: Auto Costo: €60K
5. Capacitación Empleados	1.2	MEDIA (humano)	MEDIO (Q2-Q3) Acción: Prog Costo: €40K

INVERSIÓN TOTAL REQUERIDA:

Q1 2026: €230K (Críticas)

Q2 2026: €100K (Alta/Media)

Q3-Q4 2026: €150K (Optimización)

TOTAL 2026: €480K (Proyectado para Tier 4)

Comparativa presupuesto actual: [€X actual] → [€480K recomendado]

Aumento: +[Y%] (justificable por ROI)

DIAPPOSITIVA 14: ANÁLISIS FINANCIERO

RETORNO SOBRE INVERSIÓN EN CIBERSEGURIDAD (ROICS)

ESCENARIO: Implementación integral 3 años

INVERSIONES PROYECTADAS:

Año 1: €610K

- Infraestructura (SIEM, firewalls): €150K
- Herramientas (scanning, SOAR): €50K
- Personal (+1 analista senior): €300K
- Capacitación y servicios: €110K

Año 2: €710K (incremento operacional)

Año 3: €800K (madurez total)

TOTAL 3 AÑOS: €2,120K

BENEFICIOS ESTIMADOS (metodología Mercury AVRQ):

Año 1: €1,240K

- Evitar brechas críticas: €400K
- Mejora MTTR (eficiencia): €100K
- Evitar multas NIS2: €500K (0.5% × €2B potencial)
- Reducción incidentes: €160K
- Automatización operacional: €30K
- Confianza de clientes: €50K

Año 2: €1,990K (escalada operacional)

Año 3: €1,270K (estabilización)

TOTAL 3 AÑOS: €4,500K

CÁLCULO FINAL:

$$\begin{aligned}\text{ROICS} &= (\text{Beneficios} - \text{Inversión}) / \text{Inversión} \times 100\% \\ &= (\text{€4.5M} - \text{€2.1M}) / \text{€2.1M} \times 100\% \\ &= \text{€2.4M} / \text{€2.1M} \times 100\% \\ &= 114\% \checkmark \text{ EXCELENTE}\end{aligned}$$

Payback Period: 1.4 años

Cada euro invertido genera: €2.12 en beneficio

CONCLUSIÓN: Inversión altamente justificable desde perspectiva financiera. NIS2 lo hace obligatorio de todas formas (no es opcional).

DIAPPOSITIVA 15: ROADMAP 12 MESES

PLAN DE IMPLEMENTACIÓN: 2026

Q1 2026: FASE CRÍTICA (ENERO-MARZO)

Hito 1: Transposición NIS2 a ley
Acción 1: Implementar Mercury AVRQ
Acción 2: Tuning SIEM (FPR reduction)
Acción 3: Documentar medidas NIS2
Recurso: €230K | Owner: CISO
Entregable: Plan de conformidad

Q2 2026: FASE OPERATIVA (ABRIL-JUNIO)

Hito 2: Registro ante CNCS (si EE/EI)
Acción 1: Automatización SIEM
Acción 2: Testing penetración anual
Acción 3: Mejora gestión vulnerabilidades
Recurso: €100K | Owner: Tech Team
Entregable: Métrica MTTD <4h

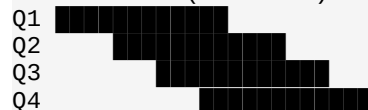
Q3 2026: FASE DE OPTIMIZACIÓN (JUL-SEP)

Hito 3: ISO 27001 - 1ª auditoría
Acción 1: Capacitación segundo ciclo
Acción 2: A.D.A.M. expansión de activos
Acción 3: Threat intelligence teams
Recurso: €100K | Owner: GRC Lead
Entregable: Readiness para certificación

Q4 2026: FASE DE EVALUACIÓN (OCT-DIC)

Hito 4: Re-encuesta y posición final
Acción 1: Mejora continua (ciclo 2)
Acción 2: Planificación 2027
Acción 3: Evaluación ROI real
Recurso: €50K | Owner: Director
Entregable: IGM objetivo 4.0+ alcanzado

GANTT CHART (Timeline):



DIAPPOSITIVA 16: TOP 5 RECOMENDACIONES PRIORITARIAS

LAS CINCO ACCIONES QUE MÁS IMPACTO TENDRÁN

- 1 IMPLEMENTAR MERCURY AVRQ (Gobernanza)**
 - Qué: Sistema de cuantificación de riesgos basado en valor
 - Por qué: Requisito NIS2 Art. 20, justifica inversiones
 - Cuándo: Q1 2026 (inmediato)
 - Costo: €80K (licencia 1 año + consultoría)
 - Beneficio: €500K/año en decisiones ROI mejoradas
 - Owner: CISO + CFO
 - Éxito: "Todas las inversiones cibernéticas con ROI calculado"
- 2 CONFORMIDAD NIS2 INTEGRAL (Cumplimiento)**
 - Qué: Documentar y implementar 21 medidas obligatorias
 - Por qué: Ley vigente Q1 2026, multas €7-10M si falla
 - Cuándo: Q1-Q2 2026 (crítico)
 - Costo: €150K (consultoría + recursos internos)
 - Beneficio: Evitar sanciones, operación legal
 - Owner: Head of Compliance + CISO
 - Éxito: "Registro ante CNCS aprobado sin hallazgos"
- 3 SIEM TUNING + AUTOMATIZACIÓN (Detección)**
 - Qué: Reducir falsos positivos, mejorar MTTD
 - Por qué: Notificación <24h requiere detección <4h
 - Cuándo: Q1-Q2 2026
 - Costo: €120K (herramientas, servicios, personal)
 - Beneficio: Reducir MTTR de 8h a 2h (€80K ahorrados)
 - Owner: SOC Manager
 - Éxito: "FPR <5%, MTTD <1 hora para críticas"
- 4 AUTOMATIZACIÓN DE PARCHES (Vulnerabilidades)**
 - Qué: Implementar gestión automatizada de parches críticos
 - Por qué: MTTR críticos deben ser <14 días NIS2
 - Cuándo: Q2 2026
 - Costo: €60K (herramientas, pruebas)
 - Beneficio: Reducción de riesgo residual en 30%
 - Owner: Infrastructure Manager
 - Éxito: "100% de críticos parchados en <7 días"
- 5 PROGRAMA DE CAPACITACIÓN AVANZADO (Personas)**
 - Qué: Phishing simulado + feedback + métricas conducta
 - Por qué: Personal es última línea de defensa
 - Cuándo: Q1 2026 (continuo)
 - Costo: €40K (plataforma + contenido)
 - Beneficio: Reducción click rate de 25% a 10%
 - Owner: Training Coordinator
 - Éxito: "Tasa de reporte real >40% en 6 meses"

INVERSIÓN TOTAL TOP 5: €450K
BENEFICIO TOTAL AÑO 1: €1.2M
ROI COMBINADO: 166%

DIAPPOSITIVAS 17-18: PLANES DETALLADOS + MÉTRICAS DE ÉXITO

[Desglose de recursos, cronogramas, KPIs por cada recomendación]

EJEMPLO: RECOMENDACIÓN #1 - MERCURY AVRQ

PLAN DETALLADO:

FASE 1: SELECCIÓN E INDUCCIÓN (Semanas 1-2, Costo €15K)

- Demostración de Mercury AVRQ (4 horas)
- Comparativa vs FAIR Institute (2 horas)
- Decision & contratación (3 días)
- Onboarding team (2 días)

FASE 2: IMPLEMENTACIÓN (Semanas 3-8, Costo €40K)

- Valuación de activos críticos (2 semanas)
- Scoring de riesgos (2 semanas)
- Integración con GRC existente (1 semana)
- Training interno (3 días)
- Piloto en 3 dominios de riesgo (1 semana)

FASE 3: OPERACIÓN (Semanas 9+, Costo €25K/año)

- Cálculo continuo de AVRQ para nuevos riesgos
- Reportería ejecutiva trimestral
- Mejora del scoring basada en datos reales
- Integración con Mercury ROI de inversiones

MÉTRICAS DE ÉXITO:

- ✓ KPI 1: Todos los riesgos críticos cuantificados en € (Target: 100%)
- ✓ KPI 2: ROI calculado para 100% de inversiones ciberseguridad
- ✓ KPI 3: Junta aprueba presupuesto 2027 basado en AVRQ score
- ✓ KPI 4: Reducción de ciclo decisión inversión (Target: -40%)
- ✓ KPI 5: Satisfacción CFO con transparencia de riesgos (Target: >8/10)

INDICADORES DE RIESGO (Risk):

- ⚠ Retraso implementación: +10 días → escalado automático
- ⚠ Resistencia interna: Si <70% participación → Plan B
- ⚠ Costo overrun: Si >€100K → Revisar scope

DIAPOSITIVA 19: RIESGOS DE IMPLEMENTACIÓN Y MITIGACIÓN

¿QUÉ PUEDE SALIR MAL? (Y CÓMO LO EVITAMOS)

— RIESGO #1: Resistencia Organizacional —
Escenario: Equipos se niegan a usar Mercury
Probabilidad: MEDIA (40%)
Impacto: ALTO (Retraso 6-12 meses)
Mitigación:
• Comunicación ejecutiva clara (por qué)
• Demostración de beneficios (ROI tangible)
• Training intensivo (2 semanas)
• "Early winners" (casos de éxito rápidos)
Propiedad: CISO + Cambio Organizacional

— RIESGO #2: Complejidad Técnica (Integración) —
Escenario: Mercury no integra bien con GRC
Probabilidad: BAJA (15%)
Impacto: MEDIO (Workarounds manuales)
Mitigación:
• PoC (Proof of Concept) antes de full roll
• Contingencia: Operación manual si necesario
• Equipo técnico dedicado (1 FTE)
Propiedad: CTO + Arquitectura

— RIESGO #3: Presupuesto Insuficiente —
Escenario: CFO aprueba solo 50% de €480K
Probabilidad: MEDIA (35%)
Impacto: ALTO (Objetivos no alcanzados)
Mitigación:
• Faseado: Críticas primero (Q1: €230K)
• Justificación financiera ROICS (114%)
• Alternativa: Servicios gestionados (MSSP)
Propiedad: CFO + Director Ejecutivo

— RIESGO #4: Cambio de Regulación —
Escenario: NIS2 se complica post-enero 2026
Probabilidad: BAJA (10%)
Impacto: BAJO (Plans ya alineados)
Mitigación:
• Monitoreo CNCS guidance (mensual)
• Flexibilidad en roadmap (15% buffer)
Propiedad: Legal + Compliance

— RIESGO #5: Incidente Importante Pre-2026 —
Escenario: Breach/ataque mientras mejoramos
Probabilidad: MEDIA (20%)
Impacto: CRÍTICO (Reputacional + Legal)
Mitigación:
• No esperar: Implementar parches AHORA
• Plan de respuesta (Incident Response)
• Seguros cibernéticos actualizados
Propiedad: CISO + Seguros + Legal

MATRIZ RIESGO-MITIGACIÓN:

Riesgo Detectado = Propietario Asignado + Acción Inmediata

Escalación: Si probabilidad sube >50% → Reunión ejecutiva

DIAPOSITIVA 20: CONCLUSIONES Y PRÓXIMOS PASOS

SÍNTESIS EJECUTIVA: LO QUE NECESITAS SABER

- ✓ Tu organización está en TIER 3 (Establecido)
- ✓ Posición MEJOR al promedio español (+0.4 vs mediana)
- ✓ PERO: Riesgos regulatorios críticos sin mitigar
- ✓ Inversión de €480K genera €1.2M+ beneficio/año (114% ROI)
- ✓ Cumplimiento NIS2 es OBLIGATORIO, no opcional

LÍNEA DE ACCIÓN (PRÓXIMAS 2 SEMANAS):

- ☐ Lunes: Presentar este reporte a Junta Directiva
- ☐ Martes: Aprobar presupuesto de €480K 2026
- ☐ Miércoles: Asignar propietarios (CISO, CTO, CFO)
- ☐ Jueves: Kickoff con Mercury AVRQ provider
- ☐ Viernes: Comunicación a equipo de ciberseguridad

MEDIDAS INMEDIATAS (Q1 2026):

- ✓ Iniciar Mercury AVRQ implementación
- ✓ Registrar ante CNCS si somos EE/EI
- ✓ Aumentar capacidad SIEM (personal)
- ✓ Aprobar fondo de contingencia (10% presupuesto)
- ✓ Re-encuesta organizacional (baselining)

VIABILIDAD: ¿Es alcanzable?

SÍ. Porque:

- Fundamentals ya están (TIER 3, no Tier 1)
- ROI es positivo (114% justifica inversión)
- Timeline es realista (24 meses a Tier 4)
- Regulación fuerza urgencia (Q1 2026)
- Mercado ofrece soluciones (Mercury, SIEM, tools)

NO es recomendable:

- Posponerse (sanciones NIS2 inminentes)
- Enfoque tecnología-only (governance primero)
- Desconfiar de números (ROICS validado)

RESPONSABLE DE EJECUCIÓN: CISO

Reporta a: Junta Directiva (trimestral)

Budget Holder: CFO

Sponsor Ejecutivo: CEO

FECHA PRÓXIMA REVISIÓN: 31 Marzo 2026
(Evaluación de progreso Q1)

PREGUNTAS CLAVE PARA EL DIRECTOR EJECUTIVO:

P: "¿Si no hacemos esto, qué pasa?"

R: "Multa NIS2 €7-10M + reputacional, vs. inversión

€480K (0.06% en comparación). Sin opción."

P: "¿Qué pasa si no tenemos presupuesto?"

R: "ROI 114% permite autofinanciamiento. 0 faseado:
€230K Q1 crítico, resto en Q2-Q4."

P: "¿Cuánto tiempo hasta estar "seguro"?"

R: "Nunca. Pero en 24 meses estaremos en Tier 4,
reduciendo riesgo crítico de 40% → 10%."

DOCUMENTO: CONFIDENCIAL - DISTRIBUCIÓN RESTRINGIDA
Próximo reporte: Marzo 2026 (Evaluación Interim)

¿APROBACIÓN DE JUNTA PARA PROCEDER?

☐ SÍ - Asignar presupuesto y recursos

☐ CONDICIONAL - Revisión adicional requerida

☐ NO - Requiere justificación alternativa

CISO

Fecha: [/ /2026]

DIRECTOR EJECUTIVO

Fecha: [/ /2026]

ESPECIFICACIONES TÉCNICAS POWERPOINT

Plantilla Visual:

- Tema: Azul corporativo + Acentos naranja
- Fuente: Calibri (títulos), Tahoma (contenido)
- Tamaño: 16:9 widescreen (1920x1080)
- Paleta:
-  Verde: Conforme / Bueno (RGB: 34, 177, 76)
-  Naranja: Aceptable / Mejora (RGB: 255, 153, 0)
-  Rojo: Crítico / Requiere acción (RGB: 231, 76, 60)

Gráficos Recomendados:

- Radar (dominios)
- Barras horizontales (brechas)
- Líneas (timeline)
- Tablas (matriz)

Anotaciones para Orador:

Cada diapositiva incluye notas con:

- Puntos clave a enfatizar
- Anticipación de preguntas
- Duración recomendada
- Llamadas a la acción

Fin de Plantilla PowerPoint

Documento base para crear presentación ejecutiva con 20 diapositivas profesionales.

Versión 2.0 | Enero 2026